TPE SUR LE CHAPITRE 1 : SUPERVISION DES SYSTEMES D'INFORMATION

ENONCES DES EXERCICES

Exercice / TP

Ex. 1.1 — Diagnostic de maturité. Appliquez la grille (tab. 1.3) à LiZbiZ-SIS. Justifiez chaque niveau et proposez deux actions correctives prioritaires.

Ex. 1.2 — Sélection de sources. LiZbiZ-SIS dispose de : 1 firewall pfSense, 2 serveurs Windows (AD + ERP), 1 serveur Linux Apache, 1 MySQL, 30 postes Windows, 1 proxy Squid. Priorisez les 5 sources à intégrer en premier au SIEM en justifiant par les menaces détectables.

Ex. 1.3 — Règle de corrélation. Rédigez en syntaxe Wazuh ou Sigma une règle détectant un mouvement latéral via SMB (T1021.002) : connexion SMB réussie depuis un poste utilisateur vers plus de 3 serveurs distincts en moins de 5 minutes.

Spécifiez niveau de gravité et mapping MITRE

RESOLUTION DES EXERCICES

Exercice 1.1 — Diagnostic de maturité SOC

Introduction

La supervision de la sécurité opérationnelle repose sur la capacité d'une organisation à détecter, analyser et répondre efficacement aux incidents. Le modèle de maturité SOC-CMM permet d'évaluer cette capacité selon trois piliers : personnes, processus et technologies. Dans le cas de LiZbiZ-SIS, PME camerounaise en pleine transformation numérique, il est essentiel de mesurer le

niveau actuel de maturité afin de définir une trajectoire d'amélioration réaliste et prioritaire.

1. **Application de la grille de maturité (SOC-CMM)**

- **Niveau actuel (LiZbiZ-SIS) :**
  - Journaux conservés seulement 7 jours localement.
  - Pas de SOC ni de SIEM.
  - Équipe réduite (2 techniciens).
  - MTTD réel > 21 jours (très élevé). → Cela correspond à un niveau 1 : Initial / ad hoc.

<u>Justification</u>

- **Personnes** : pas d'analystes N1/N2/N3, seulement deux techniciens polyvalents.
- **Processus** : pas de procédures formalisées de détection ou de réponse.
- **Technologie** : absence de SIEM, logs non centralisés, pas de corrélation.

2. **Actions correctives prioritaires et trajectoire de progression**

   2.1. **Passage au niveau 2 (Défini)**

   - Mettre en place un SIEM minimal (ex. Wazuh + ELK) pour centraliser et conserver les logs.
   - Activer les règles par défaut pour les principales sources (firewall, AD, Apache).
   - Former les techniciens à la détection et à la réponse aux incidents (N1/N2).
   - Objectif : réduire le MTTD à 2–7 jours.

   2.2. **Progression vers le niveau 3 (Géré)**

- Développer des règles personnalisées adaptées au contexte LiZbiZ-SIS (ex. corrélation SMB, brute force web).
- Mettre en place un triage des alertes pour réduire le FPR < 50 %.
- Documenter les procédures de réponse aux incidents.
- Objectif : atteindre un MTTD inférieur à 24 h.

3. Vision long terme (Niveau 4 et 5)
   - Intégrer le threat hunting et la CTI (Cyber Threat Intelligence).
   - Automatiser la réponse avec SOAR et enrichir avec du machine learning.
   - Objectif final : MTTD inférieur à 1 h, avec une détection prédictive.

Conclusion

L'analyse montre que LiZbiZ-SIS se situe actuellement au niveau 1 de maturité, caractérisé par une gestion ad hoc et une faible visibilité sur les événements de sécurité. La mise en place d'un SIEM minimal et la formation des techniciens constituent les fondations d'un SOC évolutif. Grâce à la grille Tab. 1.3, une feuille de route claire se dessine : atteindre rapidement le niveau 2, puis progresser vers le niveau 3 avec des règles personnalisées et un triage efficace. Ces mesures permettront de réduire drastiquement le temps de détection, d'améliorer la réactivité et d'aligner l'organisation sur les standards internationaux de supervision SOC, ouvrant la voie vers une sécurité intelligente et prédictive.

Exercice 1.2 — Sélection de sources SIEM

Introduction

La qualité d'un SIEM dépend directement de la pertinence des sources de données intégrées. Chaque source apporte une visibilité spécifique sur les menaces et les comportements anormaux du système d'information. Pour LiZbiZ-SIS, dont l'infrastructure est segmentée en plusieurs VLANs, la sélection initiale des sources doit viser un équilibre entre couverture des risques et faisabilité technique.

Sources disponibles

- Firewall pfSense
- 2 serveurs Windows (AD + ERP)
- 1 serveur Linux Apache
- 1 base MySQL
- 30 postes Windows
- 1 proxy Squid

Priorisation des 5 sources à intégrer en premier

1. **Firewall pfSense**
   - Détecte scans, tentatives d'intrusion, flux bloqués.
   - Source critique pour la visibilité réseau.
2. **Active Directory (Windows Server)**
   - Détecte connexions suspectes, élévations de privilèges, mouvements latéraux.
   - Source clé pour les attaques internes.
3. **Serveur Web Apache (DMZ)**
   - Détecte attaques web (SQLi, XSS, brute force).
   - Surface d'exposition directe sur Internet.
4. **Serveur ERP (Windows)**
   - Détecte accès non autorisés aux applications critiques.
   - Cible privilégiée pour vol de données.
5. **Proxy Squid**
   - Détecte navigation suspecte, exfiltration de données, usage de tunnels.

Les postes Windows et la base MySQL sont aussi importants, mais intégrés dans une seconde phase (après mise en place du SIEM minimal).

Conclusion

La priorisation des cinq sources — pfSense, Active Directory, Apache, ERP et Proxy Squid — offre une base solide pour la détection des menaces réseau, applicatives et internes. Cette approche progressive garantit une montée en puissance maîtrisée du SIEM, tout en maximisant la valeur opérationnelle des logs collectés. À terme, l'intégration des postes utilisateurs et de la base MySQL viendra compléter la visibilité globale du SOC.

Exercice 1.3 — Règle de corrélation (Wazuh / Sigma)

Introduction

Les règles de corrélation constituent le cœur analytique d'un SIEM. Elles traduisent les scénarios d'attaque en conditions détectables à partir des événements collectés. Dans le contexte de LiZbiZ-SIS, la détection du mouvement latéral via SMB est essentielle pour identifier une propagation interne après compromission initiale, conformément à la technique MITRE ATT&CK T1021.002.

Objectif

Détecter un **mouvement latéral via SMB (T1021.002)** : Connexion SMB réussie depuis un poste utilisateur vers plus de 3 serveurs distincts en moins de 5 minutes.

Exemple en syntaxe Sigma

```
yaml
title: Lateral Movement via SMB Multiple Servers
id: 1234-abcd-5678
description: Detects lateral movement via SMB when a workstation
connects successfully to more than 3 distinct servers within 5 minutes.
status: experimental
logsource:
  product: windows
  service: security
```

```
detection:
  selection:
    EventID: 4624
    LogonType: 3
    AuthenticationPackageName: NTLM
    TargetPort: 445
  timeframe: 5m
  condition: selection | count(TargetServer) > 3
fields:
  - TargetServer
  - IpAddress
  - AccountName
level: high
tags:
  - attack.lateral_movement
  - attack.t1021.002
```

Spécifications

- **Gravité** : élevée (High).
- **Mapping MITRE ATT&CK** :
  - Technique : **T1021.002 — SMB/Windows Admin Shares**.
  - Tactique : **Lateral Movement**.

Cette règle permet de repérer un comportement anormal typique d'un attaquant qui se déplace latéralement dans le réseau.

Conclusion

La règle de corrélation proposée en syntaxe Sigma permet de repérer un comportement anormal typique d'un attaquant cherchant à étendre son contrôle sur le réseau. En associant gravité élevée et mapping MITRE, elle renforce la capacité de détection proactive du SOC. Cette approche illustre la transition de LiZbiZ-SIS vers une supervision intelligente, fondée sur la corrélation et la contextualisation des événements.